



Bora Kocabıyık - 21290270

BLM4510 - Bilgi Teknolojileri ve Güvenlik Yönetimi Final Projesi

Parola Yöneticilerinde KDF ve Vault Bütünlüğü Zafiyetlerinin Güvenlik Simülasyonu

17.06.2026

Proje Amacı ve Tehdit Modeli

Bu eğitsel simülatör, parola yöneticilerinin iki temel güvenlik özelliğini gösterir: ana paroladan anahtar türetme (KDF) ve vault (kasa) dosyasının bütünlüğü. Tüm gösterimler yerel sahte verilerle yapılır. Tehdit modeli: saldırgan ana parolayı bilmez ama vault dosyasına durağan halde (at-rest) okuma/yazma erişimi vardır (çalınmış yedek, ele geçirilmiş senkron sunucusu, paylaşılan cihaz). Bu modelde bütünlük, gizlilik kadar kritiktir; saldırgan içeriği okuyamasa bile dosyayı kurcalayarak sistemi sessizce bozabilir.

KDF: PBKDF2 ve Argon2id

KDF, ana parolayı kasıtlı olarak yavaş bir işlemle anahtara çevirir ve kaba kuvvet (brute-force) saldırısında her tahmini pahalılaştırır. Apple M4'te ölçülen süreler: PBKDF2 1.000 iter $\approx$ 0,2 ms, 600.000 iter $\approx$ 113 ms (her tahmin $\sim$ 500x daha maliyetli). Argon2id ($t=3$, $m=64$ MiB) $\approx$ 90 ms; her tahminde 64 MiB bellek gerektirdiğinden GPU/ASIC ile paralel kırmaya dirençlidir. Simülatörde iki KDF de seçilebilir.

Vault Bütünlüğü: Güvensiz ve Güvenli Tasarım

Güvensiz tasarım (AES-CTR): Veri şifrelenir ama bütünlük mührü (MAC) yoktur. AES-CTR şekillendirilebilir (malleable) olduğundan saldırgan, anahtarı bilmeden şifreli baytları çevirerek düz metni öngörülebilir biçimde değiştirebilir. Güvenli tasarım (AES-GCM / AEAD): Şifreleme ve bütünlük tek adımdadır; KDF parametreleri ve sürüm numarası ilişkili veri (AAD) ile kimlik doğrulamasına bağlanır. Herhangi bir yerinde değişiklik GCM etiketini geçersiz kılar ve çözüme reddedilir.

Demo Senaryoları ve Sonuçlar

- Bit çevirme: Güvensiz kasada parola “SuperSecret!42” $\rightarrow$ “superSecret!42” olarak sessizce, öngörülebilir biçimde değişti; güvenli kasada IntegrityError ile reddedildi.
- KDF düşürme ve sürüm (in-place) değişikliği: Güvensizde fark edilmedi; güvenli de AAD sayesinde reddedildi.
- Tam dosya replay: Eski ama geçerli bir kasa her iki modda da çözüldü — AAD bunu engelleyemez, harici monoton sayaç gerekir.
- Doğrulama: Davranışlar 21/21 otomatik pytest testiyle doğrulandı.

Güvenlik sonucu: Şifreleme tek başına yeterli değildir. Parola yöneticisi, şifreli metnin ve kriptografik parametrelerin bütünlüğünü de korumalıdır; AES-GCM + AAD yerinde kurcalamayı engeller, tam dosya replay için ise harici monoton sürüm sayacı gerekir.